

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database server is a critical asset that stores sensitive customer and business data used by employees around the world to support daily operations. Keeping the server open to the public creates a significant risk of unauthorized access and data theft. If the server were disabled or compromised, the company would lose the ability to query customer data, impacting revenue and the business. This vulnerability assessment identifies the key risks associated with the publicly accessible server and provides recommendations to improve its security posture.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9
Competitor	Perform reconnaissance and surveillance of organization	2	2	4
Malicious Software	Conduct Denial of Service (DoS) attack	2	3	6

Approach

The three threat sources were selected based on the high-risk nature of a publicly accessible database server. Hackers represent a direct external threat given the server's unrestricted public access, making data exfiltration very likely. Competitors with motivation to steal customer data are a moderate risk through reconnaissance activities. Malicious software is a significant threat because an unprotected server is vulnerable to DoS attacks that could disrupt critical business operations.

Remediation Strategy

To remediate the risks identified in this assessment, the company should immediately restrict public access to the database server by implementing IP allow-listing to limit connections to authorized corporate offices only. The principle of least privilege should be enforced by assigning role-based access controls so employees only access data necessary for their job functions. Multi-factor authentication should be required for all users connecting to the server to prevent unauthorized access through compromised credentials. Additionally, all data in transit should be encrypted using TLS and the server should be monitored continuously for suspicious activity using an intrusion detection system.